

Complete Backend Architecture KYC-Based Workflow & Signature System

Overview

A scalable backend platform enabling hierarchical workflows, Aadhaar-based KYC onboarding, dynamic modules (forms/MCQs), multi-level approvals, signature capture, audit trails, and final document generation with verifiable signatures.

Tech Stack

- Node.js + Express.js (API Layer)
- MongoDB (Primary Data Store)
- AWS S3 (Documents & Signatures Storage)
- Redis / SQS (Queue & Async Jobs)
- SES / SMTP (Email Notifications)

Core Services

- Auth & RBAC: JWT auth, role-based access (HL/TL/SL/FL)
- KYC Service: Aadhaar verification via OTP/API (eKYC providers)
- Workflow Engine: Step routing, state machine, escalation
- Signature Service: Capture, store, hash-chain linking
- Module Engine: Dynamic schema-driven modules
- Document Generator: Compile responses + signatures into PDF
- Notification Service: Emails, reminders, webhooks
- Audit Log Service: Immutable action logs

End-to-End Workflow Design

- User Registration → Create account
- KYC Initiation → Send Aadhaar OTP via provider
- KYC Verification → Verify OTP; store verification token/hash
- Role Assignment → Assign HL/TL/SL/FL
- Module Creation → Admin defines schema + workflow
- Submission → SL fills module; status=PENDING; currentStep=TL
- Approval Loop → Each level reviews, signs, advances
- Signature Capture → Store image + metadata + hash + previousHash
- Notifications → Next approver notified; reminders on delay
- Final Approval → HL signs; status=COMPLETED
- Document Generation → Create PDF with all data & signatures
- Distribution → Store in S3; share link; email all stakeholders
- Audit Trail → Persist all actions for compliance

Database Schemas (MongoDB)

Users

```
{
  "_id": "user_id",
  "name": "string",
  "email": "string",
  "phone": "string",
  "role": "HL|TL|SL|FL",
  "kycStatus": "PENDING|VERIFIED|FAILED",
  "kycIdHash": "string",
  "createdAt": "timestamp"
}
```

Modules

```
{
  "_id": "module_id",
  "title": "string",
  "type": "FORM|MCQ|DOC",
  "schema": { "fields": [ { "label": "string", "type": "text|file|number|choice" } ] },
  "workflow": ["SL", "TL", "HL"],
  "createdBy": "user_id",
  "createdAt": "timestamp"
}
```

Submissions

```
{
  "_id": "submission_id",
  "moduleId": "module_id",
  "submittedBy": "user_id",
  "data": { "key": "value" },
  "status": "PENDING|IN_PROGRESS|COMPLETED|REJECTED",
  "currentStep": "role",
  "createdAt": "timestamp",
  "updatedAt": "timestamp"
}
```

Signatures

```
{
  "_id": "signature_id",
  "submissionId": "submission_id",
  "signedBy": "user_id",
  "role": "role",
  "signatureUrl": "s3_url",
  "timestamp": "timestamp",
  "hash": "string",
  "previousHash": "string"
}
```

Audit Logs

```
{
  "_id": "log_id",
  "action": "CREATED|SUBMITTED|APPROVED|REJECTED|SIGNED",
  "userId": "user_id",
  "submissionId": "submission_id",
  "timestamp": "timestamp",
  "metadata": {}
}
```

Documents

```
{
  "_id": "doc_id",
  "submissionId": "submission_id",
  "pdfUrl": "s3_url",
  "generatedAt": "timestamp"
}
```

API Design (Core Endpoints & Points)

Auth

```
POST /auth/register
POST /auth/login
GET /auth/me
```

KYC

```
POST /kyc/initiate
POST /kyc/verify
GET /kyc/status
```

Modules

```
POST /modules
GET /modules
GET /modules/:id
```

Submissions

```
POST /submissions
GET /submissions/:id
GET /submissions?role=TL
```

Signatures & Workflow

```
POST /signatures
POST /workflow/advance
GET /workflow/status/:submissionId
```

Documents & Notifications

```
POST /documents/generate
GET /documents/:id
POST /notify/email
```

API Request/Response Examples

Register

```
POST /auth/register
Request:
{ "name": "User", "email": "user@mail.com", "password": "123456" }

Response:
{ "token": "jwt", "user": { "id": "user_id", "role": "SL" } }
```

Submit

```
POST /submissions
Request:
{ "moduleId": "module_id", "data": { "field": "value" } }

Response:
{ "submissionId": "id", "status": "PENDING" }
```

Sign & Advance

```
POST /signatures
Request:
{ "submissionId": "id", "signature": "base64" }

Response:
{ "status": "SIGNED", "nextStep": "HL" }
```

Detailed Security Design

- JWT Authentication with refresh tokens
- RBAC enforcement at API and service layer
- Aadhaar KYC: Use compliant providers (OTP/eKYC); store only token/hash, never raw Aadhaar
- PII Encryption: Encrypt sensitive fields at rest
- S3 Security: Pre-signed URLs, private buckets
- Signature Integrity: Hash chaining (previousHash) to prevent tampering
- Audit Logs: Immutable logs for compliance
- Rate Limiting & IP logging
- HTTPS everywhere; secure headers (CSP, HSTS)
- Input validation & schema enforcement

Database Flow Summary

- User → stored in Users
- KYC → updates Users.kycStatus
- Module → stored in Modules
- Submission → stored in Submissions
- Signature → appended in Signatures (linked to submission)
- Workflow → updates Submissions.currentStep/status
- Document → stored in Documents (S3 link)
- Audit → every step logged in Audit Logs